

Databricks 开发环境

资产治理与企业微信告警

当前设计、实施步骤与已知限制

每日扫描

配置化规则

企业微信通知

只读优先

目标：每天扫描开发环境资产，识别超过 5 天未迁移、引用 test/tmp 数据、缺少负责人或生产关联等问题，通过可追踪的 finding 和通知队列完成闭环。

当前验证状态

AI Bot 已向 job test 成功发送 Markdown
CLI 版本 1.3.4 • 受控测试通过

生产建议

群 Webhook 做汇总和 @
自建应用做逐人告警
Secret 放入 Secret Scope / Key Vault

1. 执行摘要

这是一套面向开发环境的“发现—判断—通知—闭环”治理链路。

平台上的 Job、App、Agent、Notebook 等资产通常由实名用户创建，但长期留在开发环境会造成资源浪费、生产迁移不及时、测试数据引用混乱以及负责人不清晰等问题。方案第一阶段只做只读扫描和告警，不自动删除、停止、部署或修改资产。

推荐决策：用 Databricks Scheduled Job 承担每日调度；扫描结果和告警落到 Unity Catalog Delta 表；扫描与企业微信发送通过 notification_outbox 解耦；生产通知使用“群 Webhook + 自建应用”的组合。

当前已验证

下列结果来自本次受控测试，不等于所有企业微信租户的通用能力。

- ☐ `@wecom/cli` 1.3.4 已安装并完成扫码授权。
- ☐ 测试群 `job test` 已成功收到 Markdown 消息。
- ☐ 当前 AI Bot 发送 schema 没有显式 `@` 字段，也没有群成员列表接口。
- ☐ AI Bot 最近会话列表只能作为可发送会话范围，不能替代企业通讯录。
- ☐ 当前扫码授权适合开发验证；生产无人值守应使用专用 Webhook / 自建应用凭据。

设计边界

第一阶段做什么

每日扫描、规则判断、finding 去重、通知路由、失败重试、状态留痕。

第一阶段不做什么

不自动删除资产、不自动停止 Job、不自动发布生产、不自动改代码或表。

最关键的三点

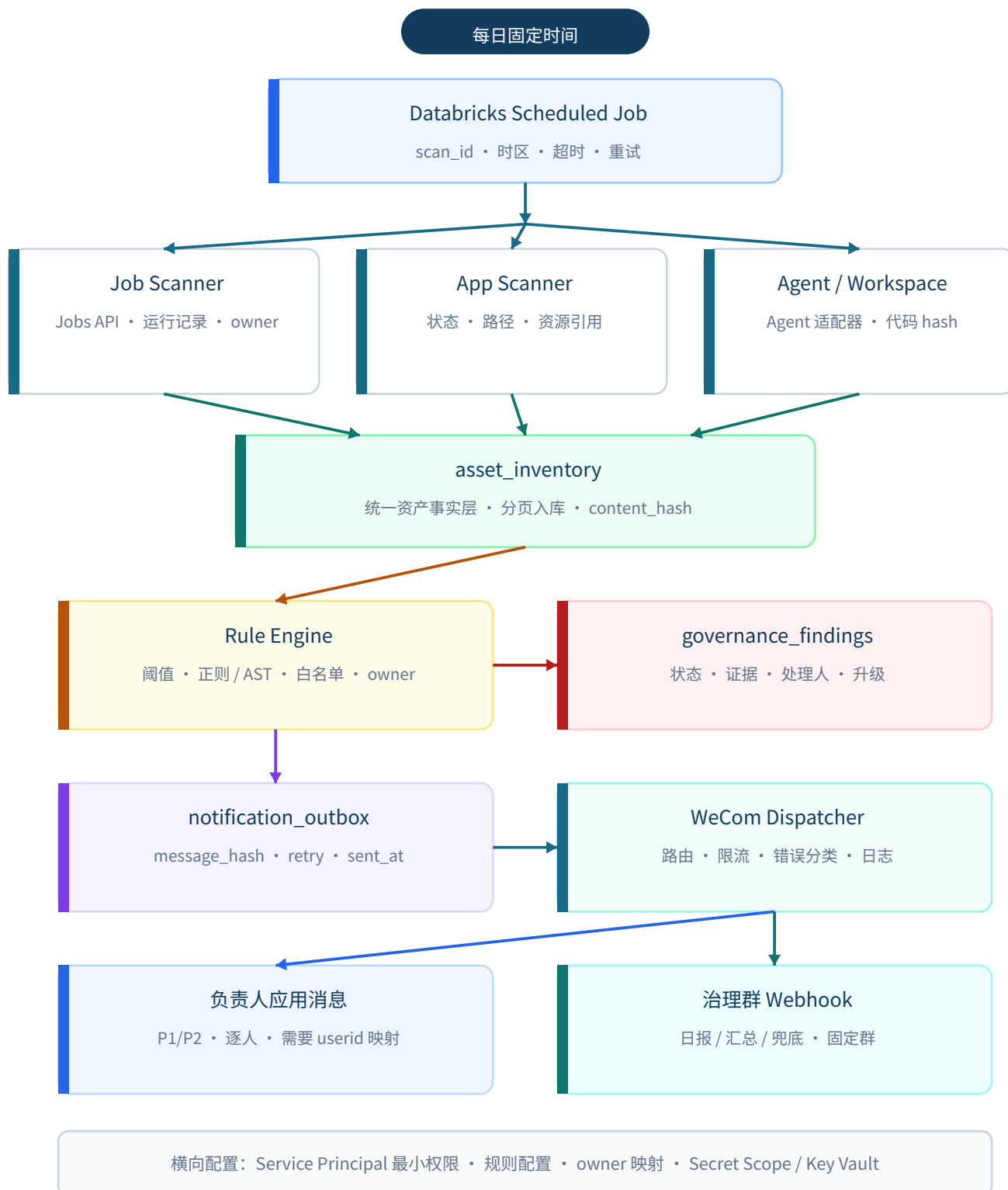
定时任务稳定；扫描结果可追溯；企业微信发送有明确通道和重试。

扩展方向

多 Workspace、Agent 适配器、工单、确认/豁免、事件驱动和治理看板。

2. 总体架构

扫描器、规则引擎和通知分发器分层，避免一个环节故障拖垮全链路。



为什么要有 notification_outbox：扫描成功不应依赖企业微信实时可用。扫描任务先落事实和告警，再由通知任务独立重试、去重、限流和升级。

推荐实现组合

模块	推荐实现	设计要点
调度	Databricks Lakeflow Job	固定时区、超时、重试、手动补跑
扫描	Python Wheel + SDK / REST	适配器、分页、限流、部分失败隔离
存储	Unity Catalog Delta	资产、规则、finding、outbox 独立建表
部署	DAB	代码、Job、权限和配置可审计
身份	Service Principal	扫描只读；通知密钥独立注入

3. 扫描与告警流程

每一批扫描都必须有唯一批次、可重跑、可追溯和幂等通知。



finding 生命周期



扫描顺序

步骤	动作	输出 / 失败处理
1	创建 scan_id，记录 Workspace、时区和开始时间。	批次记录；失败可手动补跑
2	分页读取 Job、App、Agent、Workspace File。	API 原始结果；按资产类型隔离失败
3	统一资产字段并写入 inventory。	事实快照；记录 content_hash
4	读取规则、白名单和豁免期限。	规则版本；可审计
5	生成或更新 finding。	同一问题更新 last_seen，不重复新建
6	创建 outbox，按优先级路由。	稳定 message_hash；可重试
7	发送、记录回执并做升级。	SENT / RETRYING / RESOLVED

推荐状态

OPEN → PENDING_NOTIFICATION → SENT → ACKNOWLEDGED → RESOLVED；发送失败进入 RETRYING。无效用户、权限错误和配置错误进入人工处理队列，不应无限重试。

4. 扫描范围与规则

先实现可解释、可验收的规则，再逐步提升代码解析精度。

资产类型	首期扫描内容	优先级	主要限制
Job	元数据、任务定义、运行记录、owner、Git / Bundle、生产关联	P0	需要分页、运行记录和生产目标判定
App	状态、创建者、代码路径、资源引用、更新时间	P0	不同 App 形态的可读字段可能不同
Notebook / File	路径、创建者、更新时间、源代码或 hash	P0	受 Workspace 权限、类型和路径影响
Agent	类型、创建者、更新时间、数据源、权限元数据	P1	Knowledge Assistant / Genie / Agent Bricks 需分别适配
Pipeline / Endpoint	负责人、环境、更新时间、运行或调用状态	P1/P2	建议在 MVP 稳定后接入

Job 规则口径

规则 ID	判断条件	级别	处理建议
JOB_ASSET_AGE_GT_5D	资产创建 / 登记超过 5 天，且无生产目标	P2	提醒迁移或补充生产关联
JOB_ACTIVE_RUN_GT_5D	同一运行实例持续超过 5 天	P1	立即确认是否异常运行
JOB_NO_PROD_TARGET	没有生产 Job、DAB target、release 或链接	P2	补充发布关联
JOB_NO_OWNER	owner 无法解析或已离职	P1	进入人工认领
JOB_STALE_30D	30 天未运行或未更新	P3	低频提醒或清理评估

“运行大于 5 天” 必须拆成资产年龄和单次运行时长两个规则。否则会把“创建很久但没有运行” 和 “当前运行卡住” 混成一个告警。

5. test / tmp 检测与数据模型

规则先保证可解释，再通过结构化解析降低误报。

检测层	示例	MVP 做法	后续增强
名称 / 路径	`test_job`、`/tmp/etl/`、 `dev_test_project`	大小写不敏感正则	白名单、环境标签
代码文本	`test_catalog.test_schema.table_a`、 `tmp_sales`	保留路径和脱敏命中片段	注释排除、字符串识别
结构化引用	SQL 表引用、Python 配置、实际访问表	列入后续阶段	SQL Parser、Python AST、运行历史联合

统一数据模型

表	职责	关键字段
asset_inventory	资产事实快照	scan_id、workspace、asset、owner、environment、 production_target、content_hash
governance_rules	规则和阈值配置	rule_id、severity、enabled、threshold、expression、豁免 策略
governance_findings	可追踪治理问题	finding_id、rule_id、asset_id、evidence、status、 resolved_at
notification_outbox	可靠通知队列	channel、receiver、message_hash、status、 retry_count、last_error

finding_key = hash(workspace_id + asset_id + rule_id)
message_hash = hash(finding_key + severity + template_version + evidence_hash)
同一 finding：更新 last_seen_at，不重复生成新问题；同一消息：按策略每日最多发送一次。

告警中不要保存完整源代码或密钥，只保存资产路径、规则、脱敏证据片段和 hash；消息中只展示必要摘要。

6. 企业微信通道与 @ 设计

当前 AI Bot 可用于验证；生产应按“群汇总”和“逐人告警”拆分通道。

通道	当前能力 / 适用场景	配置要求	限制
AI Bot（当前）	已验证向 `job test` 发送 Markdown；适合开发测试、普通群消息	Bot ID / Secret 或扫码授权	当前 schema 无显式 @ 字段；会话列表不是群成员目录
群 Webhook	固定治理群日报、汇总、失败兜底；可按已知标识尝试 @	Webhook URL / key、固定群	固定群；不能替代通讯录；@ 依赖已知用户标识
自建应用	负责人级详细告警、升级、部门或标签路由	corp_id、agent_id、corp_secret、可见范围、userid 映射	需要管理 Token、权限、无效用户和应用可见范围

可靠 @ 的推荐路径



不要用 AI Bot 最近会话列表推断完整群成员；它只能证明机器人最近接触过哪些会话。

不要每天从 AI Bot 最近会话列表推断完整群成员。对于实名资产，应维护“Databricks owner → 企业微信用户”的映射，并对离职、改名、无映射和重复用户做单独状态处理。

通知路由

级别	负责人	治理群	说明
P1	自建应用立即发送	同时发摘要	当前运行超过 5 天、无 owner、生产数据风险
P2	自建应用发送	日报汇总	资产年龄、无生产目标、test/tmp 引用
P3	可选	每日摘要	长期未运行、低风险治理项

7. 配置实施步骤

从最小可用链路开始，每一步都有输入、动作和验收结果。

步骤	需要配置 / 输入	动作	完成标志
0	Workspace、生产边界、时区、扫描时间	确定范围和“超过 5 天”的最终口径	需求口径冻结
1	UC catalog / schema	创建治理表和权限	四张表可写入
2	Service Principal	配置 Jobs、Apps、Workspace、Agent 最小只读权限	能分页读取资产
3	扫描适配器	实现分页、重试、统一字段、部分失败隔离	资产快照可追溯
4	规则配置	写入 5 天、test/tmp、owner、白名单和豁免	规则可改不改代码
5	负责人映射	邮箱 / 工号 → 企业微信 userid / 手机号	唯一命中或人工兜底
6	企业微信通道	测试群 Webhook + 受限可见范围自建应用	固定测试消息可达
7	Secret 管理	Webhook key、corp secret 放 Secret Scope / Key Vault	代码和日志无明文密钥
8	dry_run 测试	生成预览，再向 `job test` 和测试用户发送	内容、@、失败分支可验证
9	定时任务	创建 DAB / Lakeflow Job，设置超时、重试、失败告警	每日批次稳定执行
10	灰度上线	观察一周，逐步增加资产和通知范围	误报和失败率可接受

最小配置清单

- ☐ Databricks: Workspace 地址、Service Principal、UC catalog/schema、扫描任务时区。
- ☐ 规则: 阈值、白名单、豁免期限、通知模板、升级天数。
- ☐ 企业微信群: 专用测试群、Webhook key、测试窗口。
- ☐ 企业微信应用: corp_id、agent_id、corp_secret、可见范围和测试用户。
- ☐ 映射: Databricks owner_email / username 与企业微信 userid / 手机号。
- ☐ 安全: Secret Scope / Key Vault、dry_run、接收人白名单和发送上限。

8. 安全、可靠性与运维

告警系统本身也必须被治理：密钥、权限、重试和可观测性都要有边界。

密钥与权限

对象	建议	禁止
Databricks 扫描身份	Service Principal、最小只读权限、按 Workspace 隔离	使用个人 Token 作为生产长期凭据
企业微信密钥	Secret Scope / Key Vault 注入，按环境区分	写入 Notebook、Git、Delta 表或聊天
消息日志	状态、错误码、finding_id、message_hash、时间	记录 access_token、Secret、完整源代码
源代码证据	路径、行号范围、脱敏片段、hash	把完整代码或敏感数据发到群里

可靠发送策略

幂等 finding_key 固定；message_hash 稳定；同一 finding 不重复新建。	重试 网络、超时和限流指数退避；无效用户、权限错误不无限重试。
降级 个人通知失败时保留群摘要；扫描成功不因通知失败而回滚。	观测 记录扫描耗时、资产数、命中数、发送成功率和积压量。

建议指标

指标	用途	告警建议
scan_success_rate	判断每日扫描是否完整	低于 99% 触发平台告警
asset_scan_lag	判断数据新鲜度	超过 SLA 触发重跑
finding_new / resolved	判断治理趋势	连续增长需检查误报或整改能力
outbox_pending / retrying	判断通知积压	超过阈值切换兜底群或人工处理
invalid_receiver_rate	判断 owner 映射质量	超过阈值推动通讯录修复

9. 已知限制与风险

以下限制需要在设计、验收和运维手册中明确，避免把“可测试”误认为“可生产”。

企业微信限制

- ☐ 当前 AI Bot CLI 没有可靠的群成员查询和显式 `@` 字段；不能直接承诺通过当前通道完成指定成员 @。
- ☐ 扫码 / 长连接授权存在短期或续期运维特征；当前适合验证，不适合生产无人值守。
- ☐ 群 Webhook 面向固定群；它不是企业通讯录，也不能自动发现 Databricks 资产负责人。
- ☐ 自建应用需要可见范围、Token 管理和用户映射；无效用户、离职用户必须有人工兜底。
- ☐ Webhook、自建应用和 AI Bot 是不同能力边界，不能假设一组凭据覆盖所有场景。

Databricks 扫描限制

- ☐ Job、App、Agent、Notebook 的 API 字段不完全一致，Agent 必须按产品类型写适配器。
- ☐ Workspace 源代码读取受权限、路径和文件类型影响；不建议全量无差别导出。
- ☐ 多 Workspace 需要跨 Workspace 凭据、网络和权限；单 Workspace MVP 不能直接等同于多 Workspace 方案。
- ☐ API 分页、限流、临时错误和部分资产失败必须单独记录并支持重试。
- ☐ 仅用名称判断已迁移生产会误判；应使用 DAB、release、CI/CD 或显式 production_target。

规则与运营限制

- ☐ 正则扫描会把注释、变量名和合法临时表误判为 test/tmp；需要白名单和 AST / SQL Parser 增强。
- ☐ 创建者不一定是长期负责人；owner 解析应支持标签、run_as、Git CODEOWNERS、项目负责人和兜底团队。
- ☐ 没有去重、确认、豁免和升级机制时，每日通知会造成通知疲劳。
- ☐ 第一阶段只提醒，不自动修改、停止或删除；最终整改仍需要责任人和发布流程。

安全事件提示：本轮测试中曾在对话里提交过凭据样式的字符串。无论测试是否成功，都应在测试后旋转 Secret，并检查审计日志和使用范围。

10. 分期计划与验收标准

按单 Workspace、测试群、只读扫描的边界启动，逐步扩大。

阶段	范围	产出
Phase 1 · MVP	Job、App、Notebook；每日调度；5 天和 test/tmp；群摘要；去重	资产表、规则表、finding、outbox、日报
Phase 2 · 正式治理	Agent 适配；自建应用；负责人映射；生产目标；确认 / 豁免 / 升级	逐人告警、责任闭环、治理周报
Phase 3 · 平台化	多 Workspace、多环境、工单、事件驱动、治理看板	统一治理服务和趋势指标

第一阶段验收

- ☐ 每天固定时间自动执行，失败有重试和平台告警。
- ☐ Job、App、Notebook / Workspace File 可分页扫描并写入统一模型。
- ☐ Job 超过 5 天、单次运行超过 5 天和 test/tmp 命中均可追溯到证据。
- ☐ 支持白名单、豁免期限和同一 finding 去重。
- ☐ 测试群能收到日报；测试用户能收到应用消息或明确记录当前通道限制。
- ☐ 消息失败可重试，invalid receiver 不无限重试，所有 Secret 不出现在日志和消息里。
- ☐ 问题消失后能自动标记 RESOLVED，保留审计历史。

关键验收样例

样例	预期行为
Job 创建 8 天、无生产目标	生成 P2 finding，负责人收到提醒，治理群日报计数 +1
单次运行持续 6 天	生成 P1 finding，负责人和治理群同时收到高优先级摘要
代码引用 test/tmp 表	保存规则、路径和脱敏证据，不发送完整代码
owner 不存在或已离职	生成 P1 finding，进入人工认领，不循环发送无效用户
企业微信暂时失败	outbox 进入 RETRYING，扫描结果仍保留，达到上限后人工处理

11. 待确认事项与推荐结论

完成以下确认后即可进入 MVP 实现。

必须先确认

- ☐ “大于 5 天” 最终按资产年龄还是单次运行时长；建议拆成两个规则同时支持。
- ☐ 开发和生产是否为独立 Workspace；如果是，生产目标识别需要跨 Workspace 对比。
- ☐ 当前使用 DAB、Git、CI/CD 还是其他发布体系；它决定 production_target 的可信来源。
- ☐ Agent 的具体类型；不同产品不能复用同一套扫描 API。
- ☐ 是否允许读取 Notebook / Workspace File 源代码；如果不允许，只做元数据和运行访问表检查。
- ☐ 企业微信是否必须逐人 @；如果必须，优先准备 Webhook + 用户映射和自建应用两条通道。
- ☐ 是否需要主管升级、豁免、确认和工单闭环；建议在 Phase 2 开始前确定。

推荐结论

以单 Workspace、只读扫描、测试群为边界完成 MVP。扫描任务只负责采集和判断，通知通过 notification_outbox 解耦；普通群消息可继续用当前 AI Bot 做验证，生产通知采用群 Webhook + 自建应用组合。逐人 @ 不依赖 AI Bot 的群成员发现，而通过负责人映射表和专用企业微信通道实现。

下一步执行清单

顺序	动作	负责人 / 输入
1	冻结 5 天规则口径、Workspace 范围和通知分级。	平台负责人 + 业务代表
2	创建四张 Delta 表和只读 Service Principal。	Databricks 管理员
3	完成 Job Scanner、test/tmp 规则和 dry_run。	开发实现
4	准备测试群 Webhook、自建应用和负责人映射。	企业微信管理员
5	部署每日 Job，观察一周后评估误报和通知成功率。	平台运维

参考工作区文件：`databricks-dev-asset-governance-plan.md`、`wecom/wecom-notification-research.md`、`wecom/wecom\_notifier.py`。本文只记录设计和验证结论，不保存真实凭据。